MODULE 14 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Identity Federation at Scale

One identity, proven once by the provider you already trust, accepted across every account.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 14 of 52

admin@sthithapragna.com

Federation means AWS **never holds the password**. It trusts a provider that proves who you are.

The standards and what each carries

STANDARD	CARRIES	TYPICAL USE
SAML 2.0	A signed assertion of who the user is	Workforce sign-in from Okta, Entra ID, ADFS
OpenID Connect	A signed identity token (JWT)	Workloads such as CI pipelines; app sign-in
SCIM	User and group records	Provisioning and deprovisioning automatically
OAuth 2.0	Delegated access tokens	Apps acting for users; module 15

ON THE EXAM

SAML and OIDC prove identity. SCIM keeps the user list in step. They solve different problems.

IAM Identity Center or SAML federation per account?

IAM SAML PROVIDER PER ACCOUNT

One trust per account

- A SAML provider and roles in every account
- Users pick an account and role at the IdP
- Changes repeated across every account
- Workable for a handful of accounts

IAM IDENTITY CENTER

One trust for the organisation

- One connection to the identity provider
- Permission sets become roles in each account
- Assign groups to accounts centrally
- Access portal, CLI and AWS applications

THE TIEBREAKER

Many accounts means Identity Center. Per-account SAML providers do not scale with an organisation.

Identity Center facts the exam checks

- **Organization instance** in the management account; administration can be delegated.
- **Account instances** serve AWS applications in one account, not multi-account access.
- **Permission sets** become IAM roles. Assign them to **groups**, not individuals.
- **Multi-Region replication** since February 2026, with a multi-Region KMS key.
- Administration stays in the **primary Region**; access continues if it is disrupted.

> ON THE EXAM
>
> Older material says an instance lives in one Region only. Since 2026 it can replicate to others.

Where the identities come from

IDENTITY SOURCE	CHOOSE IT WHEN	WATCH FOR
Identity Center directory	No corporate directory, small organisation	Another user store to run
Active Directory	Corporate AD already holds the workforce	Managed Microsoft AD or AD Connector
External identity provider	Okta, Entra ID or Ping is the source of truth	Use SCIM, or provisioning is manual

ON THE EXAM

Identity Center has exactly one identity source. Choose the one that is already authoritative.

Managed Microsoft AD or AD Connector?

AWS MANAGED MICROSOFT AD

A real directory in AWS

- Windows Server AD run by AWS
- Trusts with on-premises forests
- Shareable with other accounts
- Needed by FSx and RDS for SQL Server

AD CONNECTOR

A proxy to your AD

- Stores no directory data in AWS
- Your password and lockout policies apply
- Cannot be shared across accounts
- Fails if the link to AD fails

THE TIEBREAKER

No directory data may live in AWS means AD Connector. Sharing or trusts mean Managed Microsoft AD.

SCIM: why provisioning matters

- **Automatic create, update and delete** of users and groups from the identity provider.
- **Leavers lose access** as soon as they are disabled at the provider.
- **Group membership** changes flow through, so assignments stay correct.
- **Without SCIM,** users must be created by hand before they can be assigned.
- SAML still handles sign-in. SCIM handles who exists.

> ON THE EXAM
>
> Leavers keeping access, or users missing until someone creates them, are SCIM problems.

OpenID Connect for workloads

- **IAM OIDC identity provider** trusts tokens from an issuer such as GitHub Actions.
- **AssumeRoleWithWebIdentity** exchanges the token for short-lived credentials.
- **Condition on the sub claim** to restrict which repository and branch may assume the role.
- **A trust policy without a sub condition** lets any repository on that issuer in.
- **IAM Roles Anywhere** covers workloads with X.509 certificates instead, module 17.

> ON THE EXAM
>
> Long-lived access keys in a pipeline are the anti-pattern. OIDC federation removes them.

Identity that travels into the data

- **Trusted identity propagation** carries the user's identity into data services.
- Targets include **Redshift, Athena, EMR, Lake Formation and S3 Access Grants**.
- **CloudTrail records the person,** not only the application's role.
- **Attributes for access control** pass IdP attributes as session tags for ABAC.
- Without propagation, every analyst looks identical in the audit trail.

> ON THE EXAM
>
> If the audit trail shows the application role instead of the person, the answer is trusted identity propagation.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Workforce access to many accounts	Identity Center with permission sets
Leavers keep access for days	SCIM provisioning
No directory data may be stored in AWS	AD Connector
Pipeline uses stored access keys	OIDC federation with a sub condition
Keep access if the home Region fails	Identity Center multi-Region replication
Audit shows the app role, not the person	Trusted identity propagation

ON THE EXAM

Identity questions turn on who the identity is, where it comes from, and how long it lives.

> Meridian Freight has 120 AWS accounts and uses Okta as its workforce identity provider. Engineers need console and CLI access to different accounts according to their team and role.
>
> The security team wants one place to manage access and the LEAST operational overhead.

What should the solutions architect implement?

A. An IAM SAML provider and roles in every account, deployed with StackSets

B. IAM Identity Center with Okta as the identity source, SCIM, and permission sets assigned to groups

C. IAM users in each account, synchronised from Okta by a script

D. An Amazon Cognito user pool federated with Okta

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A. SAML provider per account

Works, but 120 trusts and role sets to maintain, and no central assignment view.

B. Identity Center with Okta and SCIM

One trust, groups from Okta, permission sets assigned centrally.

C. Synchronised IAM users

Recreates long-lived credentials in 120 accounts.

D. Cognito user pool

For customers of an application, not workforce access to AWS accounts.

THE SIGNAL

Workforce, many accounts, existing IdP, one place to manage. That is Identity Center's whole purpose.

Meridian Freight connected IAM Identity Center to Microsoft Entra ID for SAML sign-in. Administrators create Identity Center users by hand when someone joins.

An audit found that people who left the company could still reach AWS accounts days after being disabled in Entra ID.

What should the solutions architect do?

A Reduce the permission set session duration to one hour

B Require MFA at every sign-in

C Enable SCIM automatic provisioning from Entra ID to Identity Center

D Run a weekly script that deletes Identity Center users not found in Entra ID

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Shorter sessions

Limits each session, but the stale user records remain.

B MFA everywhere

Good practice, unrelated to removing departed users.

C SCIM provisioning

Disabling a user in Entra ID removes them from Identity Center automatically.

D Weekly cleanup script

Still leaves access for up to a week, and is custom code to maintain.

THE SIGNAL

Manual user creation is the planted detail. Lingering leavers are a provisioning problem.

> Meridian Freight wants employees to sign in to IAM Identity Center with their existing on-premises Active Directory credentials. Company policy forbids storing any directory data, including password hashes, in the cloud.
>
> The data centre is connected to AWS over redundant Direct Connect links.

Which directory option should the solutions architect use?

A. AD Connector pointing at the on-premises domain controllers

B. AWS Managed Microsoft AD with a trust to the on-premises forest

C. Simple AD synchronised from on premises

D. Domain controllers on EC2 replicating from on premises

◆ PAUSE AND DECIDE

Which directory option should the solutions architect use?

A AD Connector

Proxies authentication to on premises and stores no directory data in AWS.

B Managed Microsoft AD with trust

A full directory in AWS, which the policy forbids.

C Simple AD

Holds its own directory, cannot trust or sync, and is closed to new customers.

D Domain controllers on EC2

Replicates the whole directory, hashes included, into AWS.

THE SIGNAL

No directory data in the cloud rules out every option except the proxy.

> Meridian Freight's GitHub Actions workflows deploy to AWS using an IAM user's access keys stored as repository secrets. Rotating them is error-prone and one key was recently exposed in a log.
>
> Only the main branch of the infrastructure repository may deploy to production.

What should the solutions architect implement?

A Rotate the access keys monthly from Secrets Manager

B An IAM user per workflow with a permissions boundary

C IAM Roles Anywhere with a certificate on each runner

D An IAM OIDC provider for GitHub, and a role trusting only that repository's main branch through the sub claim

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Monthly rotation**

Keeps long-lived keys; an exposed key is still valid for weeks.

B **Users with boundaries**

Limits damage, but multiplies the long-lived keys.

C **Roles Anywhere**

For workloads holding certificates from your PKI; hosted runners do not.

D **OIDC with a sub condition**

No stored keys; each run gets short-lived credentials, only from main.

THE SIGNAL

The pipeline already has an identity token. Trust it, and restrict the sub claim to the repository and branch.

> Meridian Freight's IAM Identity Center organization instance runs in eu-west-1, with Okta as the identity source. A regulator requires that engineers can still reach their AWS accounts if eu-west-1 is disrupted.
>
> The company wants to keep a single place to administer access.

What should the solutions architect do?

A Create a second organization instance of Identity Center in another Region

B Enable Identity Center replication to an additional Region, using a multi-Region customer managed KMS key

C Create break-glass IAM users with access keys in every account

D Delete Identity Center and recreate it in a different Region

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Second organization instance

Only one organization instance is allowed per organisation.

B Multi-Region replication

Entitlements replicate; access continues; administration stays in eu-west-1.

C Break-glass IAM users everywhere

Emergency access for a few, not workforce access, and many long-lived keys.

D Recreate elsewhere

Moves the single point of failure; does not remove it.

THE SIGNAL

Since February 2026 Identity Center replicates to additional Regions. Older material says this is impossible.

> Meridian Freight's analysts use a BI tool, signed in through IAM Identity Center, to query Athena tables governed by Lake Formation. The tool queries with its own IAM role.
>
> Auditors cannot tell which analyst ran a query, and Lake Formation cannot apply per-team permissions.

What should the solutions architect implement?

A. A separate IAM role for each analyst, chosen by the BI tool

B. CloudTrail data events for the Athena workgroup

C. Trusted identity propagation from Identity Center through the BI tool to Athena and Lake Formation

D. A session tag on the BI tool's role naming the current user

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Role per analyst**

Thousands of roles to manage, and grants duplicated per person.

B **CloudTrail data events**

Records more calls, but still by the tool's role.

C **Trusted identity propagation**

The analyst's identity reaches Athena and Lake Formation, and CloudTrail.

D **Session tag with user name**

Self-asserted by the tool, and Lake Formation does not grant on it.

THE SIGNAL

The person is lost at the application boundary. Propagation carries them through it.

What to carry out of this module

- **SAML and OIDC prove identity; SCIM provisions it.** Lingering leavers mean missing SCIM.
- **Many accounts mean Identity Center,** with permission sets assigned to groups.
- **AD Connector** stores nothing in AWS; **Managed Microsoft AD** shares and trusts.
- **OIDC for pipelines,** with a sub condition. No stored access keys.
- **Multi-Region Identity Center** since 2026; **propagation** for person-level audit.

> ON THE EXAM
>
> Stale fact: an Identity Center instance is no longer limited to one Region.